

Access Control Implementation Report

AI-Agent SOC Triage & Investigation Engine

1. Introduction

Access control is an important component of the AI-Agent SOC Triage & Investigation Engine because the system handles security alerts, investigation data, reasoning logs, and proposed containment actions. The project specifically includes a **human-in-the-loop approval gate**, ensuring that the AI can recommend actions but cannot independently execute containment. This report documents three access-control measures implemented in the security lab:

- **Access Control List (ACL):** Restricts network access to a protected service.
- **Access Control Model:** Discretionary Access Control (DAC).
- **User Access Level:** SOC Analyst with permission to investigate alerts but not execute containment.

2. Access Control List (ACL) Configuration

ACL: SSH Access Restriction

An ACL was configured to restrict SSH access to authorized network traffic.

Example ACL rule:

```
Allow TCP
Source: 192.168.1.0/24
Destination: Security Server
Port: 22
Action: ALLOW
```

A corresponding Linux firewall implementation can be configured using UFW:
`sudo ufw allow from 192.168.1.0/24 to any port 22 proto tcp`

Purpose

The ACL ensures that SSH administration is only permitted from the designated trusted network.

Traffic originating outside the authorized network is not granted access to the SSH service.

Security Benefit

This reduces the attack surface by limiting administrative access to a defined source network instead of allowing SSH connections from anywhere.

3. Access Control Model – Discretionary Access Control (DAC)

Model Selected: DAC

The project uses a **Discretionary Access Control (DAC)** approach for controlling access to system resources.

Under DAC, access permissions are assigned to users or groups, allowing authorized users to access specific files and resources based on their assigned

permissions.

For example:

```
sudo chown socadmin:socanalysts /opt/soc/reports
```

```
sudo chmod 750 /opt/soc/reports
```

This provides the following basic permission structure:

User/Group	Access
socadmin	Read, write, execute
socanalysts	Read, execute
Other users	No access

Purpose

The DAC model prevents unauthorized users from accessing investigation reports and other SOC resources.

It also supports the project's requirement that investigation information and reasoning chains remain auditable and accessible to appropriate personnel.

The project identifies investigation state, reasoning-chain logs, and test results as information that must be stored by the system.

4. User Access Level

User Role: SOC Analyst

A **SOC Analyst** was assigned an investigation-level access role.

The analyst is permitted to:

- View incoming security alerts.
- Review investigation reports and evidence.
- Examine the AI's reasoning chain.
- Review proposed containment actions.

However, the analyst's role is separated from automated containment execution.

Example Permission Structure

Role: SOC Analyst

```
Alerts:                READ
Investigation Data:    READ
Reports:               READ
Reasoning Logs:        READ
Containment:           APPROVE
Containment Execute:   DENIED
```

This reflects the project's human-in-the-loop design. The AI can recommend actions such as isolating a host or disabling an account, but a human must explicitly approve the action.

5. Example Access-Control Event

Scenario: Unauthorized User Attempts to Access SOC Reports

A user without the required permissions attempts to access the SOC investigation

directory.

Event: Unauthorized File Access

User: unauthorized_user

Resource: /opt/soc/reports

Requested Action: READ

Result: DENIED

Reason: Insufficient permissions

The DAC permissions prevent the unauthorized user from reading the investigation reports.

A SOC analyst with the appropriate role would instead receive:

User: socanalyst

Resource: /opt/soc/reports

Requested Action: READ

Result: ALLOWED

This demonstrates how access permissions can differentiate between authorized and unauthorized users.

6. Relationship to the AI-Agentic SOC

Access control is particularly important because the project produces investigation reports containing security evidence and AI reasoning.

The system's architecture is designed so that the analyst remains the final authority. The AI can investigate an alert, correlate identity/SIEM/EDR evidence, generate a timeline, and recommend a response, but the analyst makes the final decision.

This creates a separation between:

Investigation → Recommendation → Human Approval → Action

rather than allowing the AI to directly perform potentially destructive security actions.

7. Access Control Summary

Access Control Measure	Implementation	Purpose
ACL	SSH restricted to 192.168.1.0/24	Restrict network access
DAC	Linux ownership and file permissions	Restrict resource access by user/group
User Access Level	SOC Analyst	Investigate and approve, but not directly execute containment

Example Event	Unauthorized report access	Demonstrates access being denied
----------------------	----------------------------	----------------------------------

8. Conclusion

The access-control implementation provides multiple layers of protection for the AI-Agentic SOC environment. The **ACL** restricts network-level access, **DAC** controls access to system resources, and the **SOC Analyst access level** establishes appropriate permissions for investigating security incidents.

Most importantly, the implementation follows the project's human-in-the-loop security principle. The AI can perform investigation and recommend containment, but authorization remains with a human analyst. The project's evaluation criteria specifically require the approval mechanism to halt proposed containment actions and require explicit human approval.

Overall, these access controls help ensure that only authorized users can access SOC resources and that high-impact security decisions remain under human control.